Week 03 — Social Engineering and Phishing

> Slides: week03-social-engineering-and-phishing.pdf

By the end of the week you should be able to explain:

- Human factors and social-engineering techniques
- Phishing, spear phishing, smishing, vishing and impersonation
- Warning signs and safe reporting procedures

Real cases used this week

Case	Date	Technique	Lesson
Korean "daughter in an accident" call	Reported July 2018	Vishing + impersonation of family	Emotion blocks the pause; verify through a trusted route
Uber	Sep 2022	Repeated MFA approval prompts	One accepted prompt was enough
Twilio	Aug 2022	Smishing impersonating internal IT	A familiar name doesn't prove the destination
Changwon District Court warning	8 July 2025	Fake returned court mail (vishing/smishing)	Authority + unfamiliar legal language adds pressure
Hong Kong deepfake meeting	Reported 2024	Fake CFO email + fabricated video meeting	Recognition is not authorization

---

Opening case: an emergency call to a father

> **South Korea, reported July 2018.** A caller pretended to be a man's daughter. She claimed there had been an accident and asked for **20 million won urgently**. *What would make it difficult to pause?*

Answer: fear for a family member, **urgency** ("right now"), and the **familiar relationship**. A parent's emotional reaction takes over from normal checking, and the caller keeps the conversation going so there is no time to think.

The daughter was already at home

- The **real daughter heard the call**. She spoke to the caller, who **hung up**.
- **No payment occurred** in this case.

> *Which security check could work from another city?*

Answer: hang up and **call the daughter back on her known number** (a trusted, independent route), or contact another family member. A pre-agreed **family code word** also works from anywhere. The protection came from **verification**, not luck, and a check has to work even when the real person isn't in the room.

Week 2 still gives us the framework

Asset	Savings, account access and personal information
Weakness	Sending money **before independently checking** the emergency
Control	Checking with the real daughter **through a trusted route**

The weakness here is **a human behaviour**, not a software flaw, and social engineering targets exactly that.

---

1. Human Factors: social-engineering techniques

What is social engineering?

> **Social engineering** = **deception that influences a person's action.**

An attacker uses a **believable story** to make someone **reveal information, transfer money or bypass a safeguard**. Contact can come by **phone, text, email, social media or in person**. What defines it is **deception used to influence action**.

Social engineering and the human factor

- **Human factors** are the ways **attention, emotion, habits and the working situation** affect decisions.
- Social engineering is a cyberattack that **hacks the "human factor" rather than the computer code**.

Pretext and requested action

Pretext	**Requested action**
The **situation** the attacker invents	What the attacker **wants you to do**
Example: "Your scholarship payment failed."	*Example:* send a password or approve an unexpected login.

The story may be believable. **The action is what causes harm**, so focus on the action.

Why a believable request works

T: Trust	**P: Pressure**	**A: Attention**
We often cooperate with familiar people and institutions.	Fear or a deadline can narrow our attention.	A busy moment can interrupt a normal checking habit.

Authority, fear and urgency

Authority	**Fear**	**Urgency**
"I am from the court."	"Your account is involved in a crime."	"You have ten minutes."
A title suggests power.	The story threatens harm.	The deadline discourages checking.

Familiarity, reward and curiosity

Familiarity	Reward	Curiosity
"It's me. I changed my number."	"You won a tuition grant."	"Someone posted your photo."
A relationship creates trust.	The offer creates hope.	The message invites a quick look.

So there are **six levers**: authority, fear, urgency, familiarity, reward, curiosity. Real attacks usually combine several.

The harm can be personal

Money	Identity	Relationships
Losing savings may affect rent, tuition or family support.	An exposed account may reveal private messages or documents.	An attacker can use a trusted account to approach friends.

Credentials and MFA

1. **Credentials:** information used to sign in, such as a username and password.
2. **MFA:** multi-factor authentication uses **more than one type of proof**.
3. **Approval prompt:** a request to approve a sign-in. **Verify that it is the login you started.**

Uber: repeated login approvals

> **September 2022.** A contractor **initially rejected** repeated sign-in requests. **Eventually, one approval** allowed the attacker to log in. *What changed at the final approval?*

Answer: nothing about the request changed. It was just as fake as before. What changed was the **person's state**: repeated prompts caused **fatigue and annoyance**, and they approved to make it stop. This is often called **MFA fatigue**.

The decision in the Uber case

1. PASSWORD	2. REQUESTS	3. APPROVAL
The attacker **had** a contractor's password.	Repeated approval prompts **initially failed**.	**One accepted prompt** permitted access.

> *What is a more useful control than "be more careful"?*

Answer: a control that **doesn't depend on the person winning an argument with fatigue**. For example:

- **phishing-resistant MFA** such as an origin-bound **security key** (Cloudflare, Week 2), or number-matching prompts
- **limiting and alerting on repeated prompts**
- a clear **process**: "a prompt I didn't start = report it, never approve it"

"Be more careful" asks people to be perfect. Good controls assume they won't be.

A claimed identity also needs a separate check

Verified contact	Claimed identity
You reach the person or organization **through a route you already trust**.	The message *says* "university", "bank", "court" or "your friend".
You also **confirm the exact request**.	**Names, logos and profile pictures can be copied.**

Baiting and tailgating

Social engineering can also happen **face to face**.

Baiting	Tailgating
An **attractive item or offer** invites a risky action.	Someone **follows an authorized person** into a restricted area.
Example: an unknown USB labelled "Exam answers".	*Example:* a visitor asks you to hold a secure door.

> *How can you be helpful without bypassing an access rule?*

Answer: stay polite but don't let them skip the check. Offer to **call the host or security**, point them to the **reception desk**, or ask them to badge in themselves. For baiting, **don't plug in the USB**; hand it to IT or lost-and-found. You can help the person without holding the door open for them.

Conditions that support safer choices

People	Process	Technology
Someone can **pause and ask for help without embarrassment**.	Important requests have a **known verification procedure**.	Account controls **limit what one mistaken action can expose**.

Activity: the scholarship message

> Fictional campus message: "*You have been selected for a grant. Confirm your password and send the code now. Keep this offer private until approval.*"
>
> 1. Name the pretext. 2. Identify two pressures. 3. Name the risky action. 4. Choose a separate check.

Answers: story, action and check

Story and pressure	A **grant offer** (pretext) uses **reward**, **urgency** ("now") and **secrecy** ("keep this private").
Action and asset	**Password and code disclosure** could expose the **student account**.
Independent check	Open the **usual portal** or contact the **scholarship office separately**.

Secrecy is a red flag: it removes the friend or colleague who might say "that looks odd".

---

2. Phishing and Impersonation

Channels, targeting and real cases.

Phishing

> **Phishing** = **deceptive contact that seeks information or an unsafe action.** A message pretends to be trustworthy and directs you to a request, link, attachment or conversation.

Five terms describe different features

Term	Feature	Meaning
Phishing	Deception	A **broad category** of deceptive contact
Spear phishing	Targeting	**Personalized** to a person, role or group
Smishing	Text channel	Phishing through **SMS or text** messages
Vishing	Voice channel	Phishing through a **call or voice** contact
Impersonation	Claimed identity	**Pretending to be** another person or organization

Each term describes a **different feature** (what, who, which channel, whose identity), so **one attack can have several labels**.

Broad phishing vs spear phishing

Broad phishing	Spear phishing
"Your account needs attention."	"Your Tuesday project group has a new assessment file."
A **general** message goes to **many people**.	Details **match a particular** class or person.

Activity: a message knows your project

> Fictional example: a sender uses **your project title** and **your teammate's name**. It asks you to **open a new sign-in page** to read "the instructor's feedback".
>
> 1. What makes it targeted? 2. What action could create harm? 3. Where should you check?

1. **Targeted:** it uses real details (your project title and teammate's name), which makes it **spear phishing**.
2. **Harmful action:** signing in on the **new page** gives away your credentials.
3. **Check:** open the **LMS yourself** through the usual address or app and look for the feedback there, or ask the instructor or teammate **through a known channel**.

Knowing personal details doesn't prove the sender is genuine. That information may be public or come from a compromised account.

Smishing: a delivery text

> **Smishing** = phishing through SMS or text. Fictional SMS: "*Delivery failed. Update your address and pay a small fee through this link.*" *Why might a small fee feel harmless?*

Answer: the amount seems too small to worry about, deliveries are **expected and routine**, and paying feels quicker than checking. But the real goal is usually the **card details or login** you enter, not the fee. Small requests **lower your guard**.

Twilio: a text became an entry point

- **August 2022, United States.** Text messages **impersonated internal IT**.
- Some employees used **fake sign-in pages**, exposing credentials.

> *Does a familiar company name prove the destination?*

Answer: no. A name in a message or a web address can be copied. Only the **actual destination** (the full hostname) and a route **you** opened yourself matter.

Twilio: the risk extends to other people

Asset	Customer information accessible through internal tools
Event	Stolen employee credentials enabled unauthorized access
Control purpose	Protect sign-in, and **limit the reach** of a compromised account

One employee's mistake exposed **other people's** data. That is why "limit what one account can reach" is a control.

Vishing: a voice carries the request

Voice channel	A caller may claim to be support, a bank or a relative.
Pressure	Conversation can create urgency and discourage a pause.
Action	The caller asks for money, a login code or device access.

South Korea: a fake court delivery

> **Official warning, Changwon District Court, 8 July 2025.** Scammers claimed **court mail had been returned**. Calls or messages urged people to **use a link, provide information or install an app**.

1. **Claimed authority:** the **court**.
2. **Feared consequence:** being in legal trouble or missing an official legal process.
3. **Risky request:** clicking the link, giving personal information, or **installing an app** (which can take control of the phone).
4. **Official contact route:** look up the court's number **yourself** (official website), not the one in the message.

> *Why can unfamiliar legal language make someone want to cooperate quickly?*

Because you **don't understand it well enough to judge it**. It sounds official and serious, you're afraid of doing something wrong, and cooperating feels like the "safe" choice.

Unfamiliar language adds pressure

Terms to understand	A student's safer response
Court notice: a message about a legal process.	**Pause** and get help understanding the request.
Verification code: a code that **can authorize access**.	Use a **known university office or official contact route** before acting.

A verification code is effectively **a key**. Reading it to someone hands them access.

Impersonation crosses channels

Family or friend	Staff or support	Organization
A familiar relationship can support an urgent money story.	A work role can make an account request seem routine.	A university, bank or court name can suggest authority.

Deepfakes and identity claims

- A **deepfake** uses **AI to imitate a person's appearance or voice**.
- Seeing a face or hearing a voice **may increase confidence**.
- A sensitive request **still needs an independent check**.

Hong Kong: a fabricated meeting

1. EMAIL	2. VIDEO	3. TRANSFER
A fake chief financial officer (CFO) requested a confidential discussion.	A fabricated, pre-recorded meeting appeared to confirm the request.	The employee authorized transfers. Reported loss: **about HK$200 million**.

Authorization and recognition differ

Authorization	Recognition
"This request **passed our agreed verification and approval process**."	"That **looks like** my manager."
A sensitive action needs **more than recognition**.	A familiar image can influence belief.

> **Recognition is not authorization.**

Activity: one label may be too few

Contact	Labels	Reason
A. Generic email requests a new sign-in	**Broad phishing**	The story is general.
B. SMS uses your project name and a fake tutor identity	**Smishing + spear phishing + impersonation**	Text channel, targeted details, false identity
C. A caller posing as a bank asks for a code	**Vishing + impersonation**	Voice is the channel; claims to be the bank
D. A copied friend profile requests urgent money	**Impersonation** (through a message)	The precise channel is unspecified.

The asset changes the consequence

Personal situation	Workplace situation
An emergency story can target **family savings**.	A compromised account can reach **other people's information**.
A student account can expose **private information** or **interrupt study**.	A payment instruction can expose **organizational funds**.

---

3. Warning Signs and Reporting

Warning signs need context

U: Unexpected	P: Pressure	S: Sensitive action
A new contact, unusual login or sudden payment change	A deadline, threat or secrecy request blocks checking	The request concerns credentials, money or device access

One sign alone may be innocent. **Unexpected + pressure + a sensitive action together** is the pattern to stop on.

Requests that deserve a pause

1. **Password or code:** someone asks you to reveal a password or relay a login code.
2. **Payment change:** a contact introduces a new destination or an urgent transfer.
3. **Device access:** a caller asks you to install an app or enable remote access.

A familiar word can hide a different site

```
https://login.campus.example/student          <- real: belongs to campus.example
https://campus.example.verify-now.test/student <- fake: belongs to verify-now.test
```

A hostname is read **from the right**. In the second address the real owner is `verify-now.test`, and "campus.example" is just a label the attacker put in front of it.

> **The full hostname matters. Open the known portal yourself.**

Appearance is limited evidence

Stronger checks	Easy to imitate
An **expected task** and a **known contact route**	A logo, display name, fluent grammar or familiar layout
Confirmation of the exact request through the official process	**HTTPS**: it can also protect a connection to a deceptive site

HTTPS (the padlock) only means the connection is **encrypted**. It says nothing about **who** is on the other end.

Practice: an urgent tuition notice

> A **QR code** promises to prevent a tuition penalty if you sign in immediately. *What is the strongest next action?* A. Scan now B. Open the usual portal C. Ask the sender

Answer: B. Open the usual portal.

- **A** does exactly what the attacker wants. A QR code is just a hidden link.
- **C** asks the suspicious source to vouch for itself, which is not independent.
- **B** uses a route **you** obtained separately.

Pause, verify and report

1. PAUSE	2. VERIFY	3. REPORT
Stop the requested action and end pressure from the contact.	Use a **separate known route** to confirm the **exact** request.	Use the **official channel** and explain what happened.

(This is Week 1's *pause, check, report*, now with "verify **independently**" made explicit.)

A practical verification script

On a call	For a message
"I will contact the office through its official number."	Open the usual app or portal.
End the call and **find that route separately**.	Ask the known office: "*Did you send this request, and is this action required?*"

Reporting routes in South Korea

Situation	Route	Purpose
Money sent, or active voice-phishing fraud	**112** and your **bank's official contact**	Report urgently and request **payment suspension**
Suspicious SMS or a possibly malicious app	**118 KISA** (Korea Internet & Security Agency)	Get technical advice about the message or device
Campus account or university message	Known **university IT** or the responsible office	Report the message and arrange an account response

If you already acted

What happened	Immediate response
Opened a link only	Close it. Report it, and explain any downloads or permissions.
Entered credentials or approved a login	Use a trusted route to **reset access and end sessions**. Contact IT.
Installed an app or allowed remote access	**Stop using the device** for sensitive tasks. Seek help **from another device**.
Sent money	Contact **112 and the bank immediately**. Request payment suspension.

Speed matters most when money is involved.

A supportive response helps recovery

Useful response	Unhelpful response
"Thank you for telling me. What happened, and what did you already do?"	"How could you fall for that?"
Help the person reach the right reporting route.	**Shame can make someone hide information or delay help.**

Q&A: four definitions

1. What does social engineering try to influence? It uses deception to influence **a person's action**.

2. How does spear phishing differ from broad phishing? Spear phishing **tailors** the contact to a particular person, role or group; broad phishing sends a general message to many.

3. What distinguishes smishing from vishing? Smishing uses **texts**; vishing uses **voice** contact.

4. Why can impersonation overlap with the other labels? Impersonation describes the **false identity**, which can appear in **any channel**.

Q&A: the decision matters

1. Why do a correct name and logo fail to prove authenticity? A sender can **copy details** or use a **compromised account**.

2. What makes a verification route independent? You **obtain the route separately** from the suspicious contact.

3. What should change after someone shares a password? Stop the interaction, **secure the account through a trusted route** and **report** the exposure.

4. How can reporting protect someone else? A timely report can help **block the attempt** and **warn other potential targets**.

Assignment: one personal protection plan

> Write **one page** using a fictional student or one documented case. Explain how you would protect an important **account, payment or relationship**.
>
> 1. Name the **asset and threat**. 2. Explain the **manipulation**. 3. Give a **check and report route**.

A strong answer covers:

1. **Asset and threat:** which of money, identity or relationship is at stake, which technique is used (vishing, smishing, spear phishing, impersonation), and a real case to anchor it. The Week 2 asset/weakness/control table fits well here.

2. **Manipulation:** separate the **pretext** from the **requested action**, then name the levers (authority, fear, urgency, secrecy, familiarity). Explain why appearance (logo, caller ID, HTTPS) isn't proof, and that **recognition ≠ authorization**.
3. **Check and report:** pause and **verify through an independently obtained route** (plus a family code word if relevant), then give the correct **Korean reporting route** (university IT / 118 KISA / 112 + bank) and what to do "if I already acted".

Files: example plan, my submission.

Reading: Chuck Easttom, *Computer Security Fundamentals* (5th ed.); Stallings & Brown, *Computer Security: Principles and Practice* (5th ed.).

Sources for the cases (from the slides): Korea Policy Briefing (23 Jul 2018); Changwon District Court (8 Jul 2025); Uber security update (19 Sep 2022); Twilio final incident report (27 Oct 2022); Hong Kong government reply (26 Jun 2024); Cloudflare phishing incident report (9 Aug 2022); Korean Financial Services Commission guidance; U.S. FTC phishing advice.

Most important for exams

- **Social engineering** = deception that influences a person's action; it hacks the **human factor**, not the code.
- **Pretext** (the invented story) vs **requested action** (what they want you to do). **The action causes the harm.**
- **Six levers:** authority, fear, urgency, familiarity, reward, curiosity. Also **secrecy**, which removes witnesses.
- **Five labels:** phishing (broad deception), spear phishing (**targeted**), smishing (**text**), vishing (**voice**), impersonation (**false identity**). **One attack can have several labels.** Practise the A–D classification.
- **Baiting** (tempting item, e.g. a USB) and **tailgating** (following someone through a secure door).
- **Uber:** one approval after repeated prompts (MFA fatigue). A better control than "be careful": phishing-resistant MFA, limits on prompts, and a rule that a prompt you didn't start gets reported, never approved.
- **Recognition ≠ authorization** (Hong Kong deepfake, about HK$200M). Names, logos, voices, faces and **HTTPS** can all be faked.
- **Read the full hostname** from the right: `campus.example.verify-now.test` belongs to `verify-now.test`.
- **Warning signs: U**nexpected + **P**ressure + **S**ensitive action (password/code, payment change, device access).
- **Pause, verify (independently), report.** An independent route is one you **obtained separately** from the suspicious contact.
- **Korean reporting routes: 112 + bank** (money sent, request payment suspension), **118 KISA** (suspicious SMS or app), **university IT** (campus account).
- **Respond supportively.** Shame delays reporting.